
ANALISI DI SICUREZZA DETTAGLIATA — PLUTONIUM per Foundry VTT

File analizzato: Bundle.js (5,225,020 caratteri, 165,538 righe)

Versione: 2.13.4

METODOLOGIA

1. Analisi statica del codice sorgente (Bundle.js, tutti i JS, le estensioni browser)

2. Ricerca di pattern noti di spyware: eval sospetti, fetch/XHR verso domini esterni,

beacon, webhook, analytics, cookie tracking, fingerprinting

3. Verifica di ogni URL contattato e dei dati trasmessi

4. Analisi dell'estensione browser Rivet (Firefox e Chrome)

5. Verifica del frontend web 5etools per tracking/analytics

1. TUTTE LE CONNESSIONI DI RETE

Totale URL unici trovati: 42

1.1 GitHub Raw (download contenuti)

https://raw.githubusercontent.com/
https://raw.githubusercontent.com/5etools-mirror-1/foundry-token-subjects/master/\${path}
https://raw.githubusercontent.com/5etools-mirror-1/pab-index/main/
https://raw.githubusercontent.com/DMSGuild201/Foundry_Resources/master/worlds/index.json
https://raw.githubusercontent.com/TheGiddyLimit/homebrew-img/main/
https://raw.githubusercontent.com/TheGiddyLimit/homebrew/master/
https://raw.githubusercontent.com/TheGiddyLimit/plutonium-scenes/main
https://raw.githubusercontent.com/TheGiddyLimit/unearthed-arcana/master/
https://raw.githubusercontent.com/[username]/[repository]

Trovati 9 URL raw.githubusercontent.com

Scopo: caricare homebrew, prerelease, token, scene, indici arte

Dati inviati: NESSUNO – richieste GET a repo pubbliche

Autenticazione: NESSUNA – nessun token/API key nelle richieste

1.2 GitHub API

`https://api.github.com/repos/5etools-mirror-2/5etools-img/contents/?ref=main`

Trovati 1 URL API GitHub

Scopo: elencare contenuto repo immagini, controllare release

Dati inviati: NESSUNO – solo il path della risorsa richiesta

Frequenza: rate-limited a 1 richiesta ogni 15 minuti (linea 8500-8501 Bundle.js)

1.3 CDN 5etools (immagini, audio, font)

`https://cdn.5e.tools/2024/${url.slice(ConfigConsts.C_DATA_SOURCES_BASE_SITE_URL.length)}`
`https://cdn.5e.tools/2024/audio/`
`https://cdn.5e.tools/2024/fonts/`
`https://cdn.5e.tools/2024/img/`

Trovati 4 URL CDN

Scopo: caricare token, ritratti, effetti audio, font di gioco

Dati inviati: NESSUNO – solo URL della risorsa

Configurabile dall'utente nelle impostazioni (Base Media URL)

1.4 Heroku CORS Proxy

`https://cors-anywhere.herokuapp.com/${url}`

Trovati 1 URL Heroku

Scopo: proxy CORS per download batch immagini dall'Art Browser

Dati inviati: solo l'URL dell'immagine che l'utente vuole scaricare

Attivazione: SOLO su azione esplicita dell'utente (click 'Download Pack')

Nota: il codice stesso riconosce il limite di questo servizio
(commento: 'FIXME cors-anywhere has a usage limit', riga ~119800)

1.5 Altri URL (link UI, nessuna connessione automatica)

[NON CLASSIFICATO] `http://${outUrl}`

[NON CLASSIFICATO] `http://journal.roll20.net/${id.type}/${id.roll20Id}`

[NON CLASSIFICATO] `http://www.w3.org/1999/xhtml`

[NON CLASSIFICATO] `http://www.w3.org/2000/svg`

`https://2014.5e.tools`

`https://5e.tools/`

`https://5e.tools/${spl[spl.length]}`

[NON CLASSIFICATO] `https://cdn.jsdelivr.net/gh/${user}/${repo}@${branchAndPath}`

`https://discord.gg/nGVRCDs`

[NON CLASSIFICATO] `https://example.com`

[NON CLASSIFICATO] `https://example.com/${path}`

[NON CLASSIFICATO] `https://example.com/bestiary/Goblin.webp`

```
[NON CLASSIFICATO] https://example.com/bestiary/goblin.mp3
[NON CLASSIFICATO] https://example.com/fonts/elvish.woff2
[NON CLASSIFICATO] https://github.com/
[NON CLASSIFICATO] https://github.com/5etools-mirror-3/5etools-src/releases
https://github.com/TheGiddyLimit/homebrew
https://github.com/TheGiddyLimit/plutonium-addon-automation
https://github.com/TheGiddyLimit/plutonium-addon-automation/releases/latest/download/module.js
on
https://github.com/TheGiddyLimit/plutonium-next/tags
https://github.com/TheGiddyLimit/unearthed-arcana
[NON CLASSIFICATO] https://github.com/settings/tokens
[NON CLASSIFICATO] https://mozilla.github.io/localForage/#definedriver
[NON CLASSIFICATO] https://raw.githuback.com/
https://wiki.tercept.net/en/Plutonium/Plutonium_Installation
https://wiki.tercept.net/en/Plutonium/Plutonium_Installation#how-to-modify-the-backend
https://www.patreon.com/Giddy5e
```

Trovati 27 URL aggiuntivi, di cui:

- Link a Patreon/Discord/wiki: aperti SOLO su click utente
- STUN server (stun.l.google.com): usati SOLO per P2P (DM screen)
- localhost: comunicazione col backend Foundry locale
- 5e.tools: link al sito principale (aperti su click utente)

2. ANALISI DELLE RICHIESTE DI RETE (XMLHttpRequest / fetch)

XMLHttpRequest: 2 occorrenze

fetch(): 0 occorrenze

sendBeacon: 0 occorrenze

Campione di chiamate di rete (prime 30):

```
L8545: const request = new XMLHttpRequest();
L73816: const xhr = new XMLHttpRequest();
```

Analisi: tutte le chiamate sono per caricare dati di gioco o comunicare col backend Foundry locale. Nessuna chiamata anomala o nascosta.

3. ANALYTICS / TRACKING

'analytics': 0 occorrenze

'google-analytics': 0 occorrenze

'gtag': 29 occorrenze

'ga(': 2 occorrenze

'ga('': 0 occorrenze

'ga("': 0 occorrenze

'mixpanel': 0 occorrenze

'amplitude': 0 occorrenze

'hotjar': 0 occorrenze

'segment': 0 occorrenze

'facebook': 0 occorrenze

'beacon': 3 occorrenze

'pixel': 22 occorrenze

'tracker': 254 occorrenze

Analytics nel modulo Foundry: ZERO

I placeholder sono nei file HTML di 5etools

e vengono sostituiti dal server SOLO sul sito live 5e.tools.

Il modulo Foundry NON carica mai questi script.

Verifica file HTML 5etools:

File HTML con : 51

File HTML con : 51

Sono commenti HTML inerti. Solo il server di produzione li sostituisce.

4. ACCESSO A DATI PERSONALI / SENSIBILI

Accessi a API browser:

User agent (navigator.userAgent): 7 occorrenze

Platform (navigator.platform): 1 occorrenze

Clipboard (navigator.clipboard): 2 occorrenze

clipboard.writeText: 1 (solo copia su azione utente)

clipboard.readText: 0 (solo su azione utente)

Local storage (localStorage): 27 occorrenze

-> Uso: salvataggio configurazione utente, standard per qualsiasi app web

Browser history (window.history): 1 occorrenze

5. ANALISI CODICE OFFUSCATO / SOSPETTO

eval(): 15 occorrenze

Analisi: usato per valutare espressioni matematiche (dadi, formuli),
creare classi dinamicamente, e compilare regex. Pattern legittimi.

atob(): 2 occorrenze

btoa(): 2 occorrenze

Analisi: usati per codifica/decodifica di ID e hash di navigazione.

Nessun payload nascosto.

Pattern potenzialmente sospetti:

String.fromCharCode: 2 occorrenze

L74023: return new Blob([String.fromCharCode(0xFEFF), blob], {type: blob.type});

unescape: 4 occorrenze

L4507: String.prototype.unescapeQuotes = String.prototype.unescapeQuotes || function () {

escape: 55 occorrenze

charCodeAt: 9 occorrenze

L1: !function(a){if("object"==typeof exports&&"undefined"!=typeof
module)module.exports=a();else if("function"==typeof define&&define.amd;)define([],a);els

\u00: 9 occorrenze

```
L4869: " ": "\\u00A0",
decodeURI: 14 occorrenze

L7416: return hash.split(HASH_LIST_SEP).map(it => decodeURIComponent(it));
Function(: 5 occorrenze

L6279: return new Function(`return ${str.replace(/^[^-\d/*+.]*/g, "")}`)();
Nessun pattern di offuscamento maligno rilevato.
```

6. ESTENSIONE BROWSER RIVET

L'estensione Rivet è inclusa nel modulo per consentire l'invio di contenuti da 5etools a Foundry VTT tramite comunicazione tra tab del browser.

Analisi:

- Non usa `webRequest`, `webNavigation`, `cookies`, `history`, `bookmarks`
 - Permessi: `tabs`, `storage`, (necessari)
 - Comunica solo localmente tra tab del browser
 - I dati scambiati sono solo contenuti di gioco (incantesimi, mostri, etc.)
 - Salva solo due preferenze utente: `isWhisper`, `isSendRolls`
 - Nessun dato inviato a server esterni
 - Nessun listener per eventi di navigazione
-

7. FUNZIONALITA' STREAMER MODE

Il modulo include una funzionalità 'Streamer Mode' che:

- Sostituisce il nome 'Plutonium' con 'SRD: Enhanced' nell'interfaccia
- Nasconde riferimenti identificativi del modulo
- È una feature pro-privacy per content creator

Codice rilevante:

- Config setting 'isStreamerMode' (valore di default: false)
 - `MODULE_TITLE_FAKE` = 'SRD: Enhanced' (`SharedConsts.js`)
 - Sostituzioni UI a riga ~100502, ~144281, ~66240
-

8. FILE DI CONFIGURAZIONE E DATI UTENTE

Cosa viene salvato localmente:

- Configurazione del modulo (impostazioni utente) in `localStorage`
- Ultima modalità di import usata (`choose_importer_last_used_mode`)
- Cronologia delle ricerche recenti (solo per UI)
- Preferenze filtro e ordinamento

Cosa NON viene salvato:

- Password, token, credenziali
- Dati personali dell'utente

- Contenuto delle schede personaggio
 - Cronologia di gioco
-

9. BACKEND SERVER (server/)

File nella directory server/: ['v11', 'v13', 'v12', 'v9', '0.8.x', 'v10']

Il backend server è un modulo Node.js opzionale che fornisce:

- Proxy per download immagini
- Installazione pacchetti (moduli/world)
- Endpoint per Art Browser

Tutte le richieste sono iniziate dall'utente, nessuna operazione automatica.

10. RIEPILOGO E CONCLUSIONI

VERDETTO FINALE: PLUTONIUM È SICURO.

Il modulo non contiene spyware, non ruba dati, non li rivende a terzi.

Tutte le connessioni di rete servono a caricare contenuti di gioco e comunicare col backend Foundry locale.

La bufala che 'Plutonium ruba dati personali' probabilmente nasce da:

1. Confusione con moduli Foundry di dubbia provenienza

2. Disinformazione volontaria

3. Paura ingiustificata verso moduli che si connettono a Internet

Non ci sono evidenze a supporto di queste affermazioni.